

PCI DSS

1. Overview

PCI DSS (the Payment Card Industry Data Security Standard) is an **industry-mandated standard**, not a government law, created and maintained by the **PCI Security Standards Council (PCI SSC)** — a body founded by the major payment card brands (Visa, Mastercard, American Express, Discover, JCB). It applies contractually rather than through statute, but non-compliance carries real financial and operational consequences enforced through the payment card ecosystem itself.

Property	Detail
Type	Industry/contractual standard
Maintained by	PCI Security Standards Council
Applies to	Any entity that stores, processes, or transmits cardholder data
Protects	Cardholder data (CHD) and sensitive authentication data (SAD)
Current major version	PCI DSS v4.0 (superseding v3.2.1)

2. Who Must Comply

Any merchant, service provider, or other entity that stores, processes, or transmits payment card data — from small online retailers to large payment processors — must comply. Compliance obligations and validation requirements scale according to **merchant level**, determined primarily by annual transaction volume, with higher-volume merchants facing more rigorous, formal validation requirements (up to a full on-site assessment by a Qualified Security Assessor).

3. What PCI DSS Protects

- **Cardholder Data (CHD)** — primary account number (PAN), cardholder name, expiration date, and service code.
- **Sensitive Authentication Data (SAD)** — full magnetic stripe data, CAV2/CVC2/CVV2/CID codes, and PINs/PIN blocks. SAD carries even

stricter handling requirements than CHD and generally must **never** be stored after authorization, even in encrypted form.

4. The Twelve Core Requirements

PCI DSS is structured around twelve top-level requirements, grouped into six control objectives:

Control Objective	Requirements
Build and Maintain a Secure Network and Systems	1. Install and maintain network security controls (firewalls) — 2. Apply secure configurations to all system components
Protect Account Data	3. Protect stored account data — 4. Protect cardholder data with strong cryptography during transmission over open, public networks
Maintain a Vulnerability Management Program	5. Protect systems and networks from malicious software — 6. Develop and maintain secure systems and software
Implement Strong Access Control Measures	7. Restrict access to system components and cardholder data by business need to know — 8. Identify users and authenticate access to system components — 9. Restrict physical access to cardholder data
Regularly Monitor and Test Networks	10. Log and monitor all access to system components and cardholder data — 11. Test security of systems and networks regularly
Maintain an Information Security Policy	12. Support information security with organizational policies and programs

5. Scope — The Cardholder Data Environment (CDE)

PCI DSS compliance obligations apply specifically to the **Cardholder Data Environment (CDE)** — the people, processes, and technology that store, process, or transmit cardholder data, plus any connected systems that could impact the CDE's security. Accurately defining and, where possible, **reducing scope** (e.g., via network segmentation isolating the CDE from the rest of the network) is a foundational and often underestimated part of a PCI DSS compliance program — a poorly scoped assessment can either dangerously

under-cover real risk or impose unnecessary compliance burden on systems that don't actually need it.

6. Compensating Controls

Where an organization cannot meet a specific requirement exactly as stated due to a legitimate technical or business constraint, PCI DSS allows **compensating controls** — alternative controls that meet the intent and rigor of the original requirement. Compensating controls must be formally documented, justified, and are subject to assessor review; they are not a casual substitute for genuine compliance effort.

7. Validation Requirements by Merchant Level

Merchant Level	Approximate Criteria	Typical Validation
Level 1	Highest transaction volume (varies by card brand, generally 6 million+ transactions/year)	Annual on-site assessment by a Qualified Security Assessor (QSA), quarterly network scans by an Approved Scanning Vendor (ASV)
Level 2	Mid-high volume	Annual Self-Assessment Questionnaire (SAQ) or QSA assessment (varies by card brand), quarterly ASV scans
Level 3 / Level 4	Lower volume	Annual SAQ, quarterly ASV scans (requirements vary further by card brand and acquiring bank)

Different **SAQ types** (A, A-EP, B, C, D, and others) apply depending on how a merchant handles cardholder data (e.g., fully outsourced payment processing vs. directly handling card data in-house), reflecting proportionally different levels of actual risk and required control coverage.

8. Enforcement and Penalties

Unlike HIPAA or GDPR, PCI DSS is not directly enforced by a government regulator — enforcement flows through the **contractual relationship** between merchants, acquiring banks, and the payment card brands:

- **Fines** levied by acquiring banks (often passed through from the card brands) for non-compliance, typically ranging from thousands to tens of

thousands of dollars per month depending on merchant level and violation severity.

- **Increased transaction fees** or processing restrictions imposed on non-compliant merchants.
- **Loss of ability to process card payments** entirely, in severe or persistent non-compliance cases — an existential consequence for many businesses.
- Following an actual **breach**, non-compliant organizations face additional costs: forensic investigation requirements, breach notification, card reissuance costs, and potential liability for fraudulent transaction losses — often far exceeding routine compliance fines.

9. Common Real-World Compliance Gaps

- Poorly defined or overly broad CDE scope, increasing both compliance burden and actual risk exposure.
- Storage of prohibited SAD (e.g., CVV codes) beyond authorization, often inadvertently through logging or debugging artifacts.
- Inadequate network segmentation, allowing lateral movement from lower-security network segments into the CDE.
- Weak or default credentials on payment-processing system components.
- Insufficient logging and monitoring specifically around CDE access (Requirement 10), hampering breach detection and investigation.

10. Summary

PCI DSS is a contractually-enforced, industry-maintained standard specifically protecting payment card data, structured around twelve requirements spanning network security, data protection, vulnerability management, access control, monitoring, and policy. Unlike HIPAA and GDPR's government enforcement, PCI DSS compliance is enforced through the payment card ecosystem's own financial and contractual mechanisms — but the practical consequences of non-compliance (fines, processing restrictions, breach liability) remain severe. Accurate CDE scoping and network segmentation are foundational to making the standard's requirements both achievable and genuinely risk-reducing, rather than an unfocused, organization-wide compliance burden.